



THREAT ADVISORY

**ATTACK
REPORT**

Unknown Attackers exploit several vulnerabilities in Zimbra Collaboration Suite

Date of Publication

August 17, 2022

Admiralty Code

A2

TA Number

TA2022174

Summary

The Zimbra Collaboration Suite (ZCS) email servers experienced multiple breaches between July and early August 2022. The exploitation of CVE-2022-27925, a remote-code-execution (RCE) vulnerability in ZCS, was most likely the cause of these incidents.

⚙ CVE Table

CVE	NAME	PATCH
CVE-2022-27924	Memcached poisoning with unauthenticated request	✓
CVE-2022-27925	Arbitrary File Upload Vulnerability	✓
CVE-2022-37042	Authentication Bypass Vulnerability	✓
CVE-2022-30333	Directory Traversal Vulnerability	✓
CVE-2022-24682	ZCS Cross-Site Scripting Vulnerability	✓



Potential MITRE ATT&CK TTPs

TA0043 Reconnaissance	T1589 Gather Victim Identity Information	TA0001 Initial Access	T1189 Drive-by Compromise
TA0002 Execution	T1059 Command and Scripting Interpreter	TA0004 Privilege Escalation	T1068 Exploitation for Privilege Escalation
TA0006 Credential Access	TA0003 Persistence	TA0005 Defense Evasion	T1070 Indicator Removal on Host
TA0008 Lateral Movement	T1210 Exploitation of Remote Services		



Technical Details

#1

By exploiting this vulnerability (CVE-2022-27924), an unauthenticated attacker can overwrite arbitrary cache entries by injecting arbitrary Memcache commands into a targeted ZCS instance.

#2

Around 1,000 ZCS instances were exploited by chaining CVE-2022-27925 and CVE-2022-37042. ZCS includes mboximport functionality, which accepts ZIP archives and extracts files from them. An attacker can circumvent authentication and upload arbitrary files to the system, resulting in a directory traversal and remote code execution.

#3

Another directory traversal issue (CVE-2022-30333) in RARLAB UnRAR on Linux and UNIX lets adversaries write to files during an extraction procedure.

#4

ZCS webmail client has another cross-site scripting (XSS) vulnerability (CVE-2022-24682) that allows malicious actors to steal session cookie files.

Vulnerability Details

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-27924	Zimbra Collaboration: 8.8.15 - 9.0.0	cpe:2.3:a:zimbra:collaboration:8.8.15:-:*:*:*:*:* cpe:2.3:a:zimbra:collaboration:9.0.0:-:*:*:*:*:*	CWE-74
CVE-2022-27925	Zimbra Collaboration: 8.8.15 - 9.0.0	cpe:2.3:a:zimbra:collaboration:8.8.15:-:*:*:*:*:* cpe:2.3:a:zimbra:collaboration:9.0.0:-:*:*:*:*:*	CWE-434

CVE ID	AFFECTED PRODUCTS	AFFECTED CPE	CWE ID
CVE-2022-37042	Zimbra Collaboration: 8.8.15 - 9.0.0	cpe:2.3:a:zimbra:c ollaboration:8.8.15 :~:*:*:*:*:* cpe:2.3:a:zimbra:c ollaboration:9.0.0:- :*:*:*:*:*	CWE-287
CVE-2022-30333	UnRAR: 6.0.3 - 6.11 on Linux and Unix	cpe:2.3:a:rarlab:un rar:*:*:*:*:*:* cpe:2.3:a:linux:linu x_kernel:- :*:*:*:*:* cpe:2.3:o:opengro up:unix:- :*:*:*:*:*	CWE-22
CVE-2022-24682	Zimbra Collaboration: 8.8.15 - 8.8.15	cpe:2.3:a:zimbra:c ollaboration:*:*:* :*:*:*:*	CWE-79

🔗 Patch Links

https://wiki.zimbra.com/wiki/Security_Center

<https://www.rarlab.com/rar/rarlinux-x32-612.tar.gz>

🔗 References

<https://www.cisa.gov/uscert/ncas/alerts/aa22-228a>

<https://www.hivepro.com/zero-day-vulnerability-in-zimbra-servers-being-exploited-in-the-wild/>

<https://www.hivepro.com/vulnerability-in-zimbra-that-steals-clear-text-credentials-from-users/>

<https://www.hivepro.com/vulnerability-in-the-unrar-leads-to-code-execution-in-zimbra/>

What Next?

Book a free demo with **HivePro Uni5** to check your exposure to this advisory. HivePro Uni5 is a Threat Exposure Management Solution that proactively reduces an organization's attack surface before it gets exploited.



At Hive Pro we take a long hard look at your vulnerabilities so you can bolster your defenses and fine-tune your offensive cybersecurity tactics.

REPORT GENERATED ON

August 17, 2022 • 4:34 AM

© 2022 All Rights are Reserved by HivePro



More at www.hivepro.com